Le projet expliqué simplement — V2

> Pour comprendre le projet sans lire le dossier technique, le présenter en trois minutes, et répondre aux questions du jury. Tous les chiffres viennent de mesures réelles (voir `DOSSIER-ECRIT-V2.md`, partie 10).

---

1. En trente secondes

On dépose les documents d'une organisation (PDF, Word, Excel…). Le système lit tout, relève ce qui est **écrit noir sur blanc** dans les documents, puis mène une analyse de risques en sept étapes avec des modèles d'IA qui tournent **sur un ordinateur local**. Pour chaque risque, il montre la phrase exacte du document qui le justifie. Un analyste humain relit, corrige et valide. Si on ajoute un document plus tard, le système ne refait pas tout : il met à jour ce qui change.

L'idée centrale : le modèle d'IA *propose*, le programme *vérifie*, l'humain *décide*.

2. Le problème

Une analyse de risques prend des jours, demande des experts, et doit être refaite à chaque changement. L'IA lit vite et rédige bien, mais elle **invente** (un composant qui n'existe pas, un chiffre faux), elle ne connaît pas le contexte, et un document piégé peut la détourner. Le défi n'est donc pas « faire écrire l'IA », c'est **encadrer l'IA**.

3. Comment ça marche, pas à pas

Le parcours de l'analyste (le site)

Page	Ce qu'on y fait	Ce qui se passe derrière
① Documents	Déposer des fichiers ou un dossier	Chaque document est converti en texte, marqué comme **donnée non fiable** ; le système en extrait des faits et signale les contradictions entre documents
② Lancer l'analyse	Un bouton	Le pilote déroule les sept étapes, contrôle chacune, relance une fois si besoin
③ Résultats	Lire le registre, la synthèse, exporter	Rapport exécutif ou **dossier complet** avec tous les liens, en PDF, HTML ou ZIP
④ Validation	Décider, point par point	Accepter, modifier, rejeter, choisir entre deux valeurs, répondre à une question

Les sept étapes

1. **Existant et actifs** : qu'est-ce qui a de la valeur ? (serveurs, logiciels, données, prestataires)
2. **Choix de la méthode** : quelle grille de menaces ? (STRIDE, LINDDUN, EBIOS RM…) — justifié.
3. **Menaces** : qu'est-ce qui peut mal tourner pour chaque actif ?
4. **Évaluation** : probabilité × impact = niveau.
5. **Traitement** : réduire, transférer, éviter ou accepter, avec des contre-mesures.
6. **Registre** : le tableau final des risques.
7. **Synthèse** : une page pour décider.

Ce que fait le modèle, ce que fait le programme

Le modèle (IA)	Le programme (code)
Lit un passage et en extrait des faits	Vérifie que chaque fait cité existe **mot pour mot** dans le document
Propose des actifs, des menaces, des mesures	Assemble les tableaux, pose les identifiants, retire les doublons
Écrit un jugement (probabilité, impact)	**Calcule le niveau** avec la matrice
Rédige un court texte de lecture	Calcule tous les chiffres et refuse le texte si un chiffre est faux
Juge un point douteux (modèle d'une autre famille)	Passe en premier : sources inventées, identifiants absents, nombres introuvables

4. Les cinq idées à retenir

1. **Une preuve pour chaque phrase.** Un fait porte un numéro `[E12]` qui renvoie à l'extrait exact d'un document. Pas de preuve,

pas d'affirmation : « non documenté ».

1. **Le code fait ce qui doit être exact.** Un petit modèle se trompe parfois ; un niveau de risque, un identifiant ou un total

ne doivent pas dépendre de sa chance.

1. **L'humain décide, avec le contexte.** Pour chaque point : la preuve, le document, les valeurs en conflit.
2. **Rien n'est écrasé.** On archive avant de refaire ; on ne supprime que sur confirmation ; une décision survit aux mises à jour.
3. **On dit ce qui ne marche pas.** Chaque limite est écrite avec son chiffre.

5. Ce qui vient du cours, ce qui est personnel

	Production école (groupe)	Améliorations personnelles (V2)
Quoi	Système d'agents opencode, cas ShoPix, 14 risques validés, dossier, soutenance	Ingestion, site web, pilote, dossier de connaissance, validation, exports, mise à jour
Quand	23–24 septembre	4–12 octobre
Trace	Tag Git `ecole-2026-09-24`	144 commits ensuite

Équipe de la V1 : Melvin Raimbault, Lucas Huard, Jérémy Lessa, David Amaro Monteiro (groupe de 4).

À dire à l'oral : « La V1 est ce que nous avons rendu en cours, en groupe. Sa feuille de route listait ce qui manquait ; la V2 est ce que j'ai fait ensuite pour y répondre, seul, hors cours. »

6. Ce qui marche et ce qui ne marche pas

Marche : lecture de documents de tout format ; 97 % de faits exacts ; registre produit en quelques heures de calcul local ; mise à jour en 13 minutes sans toucher à l'existant ; export du dossier complet.

Ne marche pas encore : trop de risques « Critique » (48 à 56 %) ; quelques doublons d'actifs ; des citations qui n'existent pas (détectées, pas toutes corrigées) ; validation humaine lourde (plusieurs

centaines de points sur un gros cas) ; **le site n'est pas sécurisé** (pas d'authentification) ; un seul essai d'injection en direct avec le modèle (15/10), à répéter sur d'autres cas.

8. Questions probables du jury

Sur la démarche de risque

Question	Réponse
Pourquoi STRIDE ?	C'est la grille par défaut du sujet, simple, et adaptée aux flux de données. Le système en propose d'autres (LINDDUN pour la vie privée, EBIOS RM, PASTA) et **justifie** le choix à l'étape 2.
Comment le niveau de risque est-il décidé ?	Par une matrice probabilité × impact appliquée par le **programme**. Le modèle ne propose que les deux valeurs et leur justification.
Les contre-mesures sont-elles réalistes ?	Elles sont sourcées (ISO 27002, ANSSI) mais proposées par un petit modèle : c'est un **premier jet à relire**, pas un plan.
Le registre est-il fiable ?	Il est cohérent et traçable. Il surévalue : 48 à 56 % de « Critique ». C'est pourquoi la validation humaine existe.

Sur l'IA

Question	Réponse
Votre IA hallucine-t-elle ?	Oui, comme tout modèle. Mesures : preuve citée et vérifiée mot pour mot (97 % de faits exacts), sources et CVE inventées **retirées par le code**, juge d'une autre famille, validation humaine. Reste : des citations inexistantes que le contrôle **signale** sans toutes les corriger.
Pourquoi un petit modèle local plutôt qu'un grand modèle en ligne ?	Confidentialité (aucune donnée ne sort), coût nul, reproductibilité. Prix à payer : qualité de jugement moyenne et lenteur ; c'est pour cela que le code vérifie.
Pourquoi deux modèles différents ?	Un modèle a tendance à approuver ses propres erreurs. Le juge est d'une autre famille.
Qu'est-ce qu'un « dossier de preuves » ?	Au lieu de donner tous les documents à l'agent, on lui donne les passages et faits pertinents pour son étape, chacun numéroté. Il cite ces numéros.
Et si un document contient une consigne piégée ?	Tout document est une **donnée** encadrée par un marqueur ; la phrase piégée est conservée telle quelle, signalée, et n'entre dans aucune consigne. Testé sur une vraie fixture (11 contrôles), puis le 15/10 avec le modèle en direct sur la chaîne complète : aucune consigne exécutée (116 risques, niveaux répartis, tous sourcés). **Limite** : un seul essai.

Sur le prototype

Question	Réponse
Qu'avez-vous codé vous-même ?	La V1 était sans code (consignes). La V2 compte ≈ 22 500 lignes de Python et ≈ 10 000 lignes de tests. J'ai utilisé **Claude (Claude Code)** comme assistant de développement, sous ma direction et ma validation ; c'est cité dans le dossier.
Comment savez-vous que ça marche ?	Des centaines de vérifications automatiques sans modèle, plus des essais réels mesurés. L'essai réel de la mise à jour a trouvé trois défauts que les tests ne voyaient pas : ils sont corrigés.

Question	Réponse
Combien de temps pour une analyse ?	Environ 3 heures de calcul pour 22 documents (70 minutes d'indexation, 2 heures de chaîne). Ajouter un document : 13 minutes.
Pourquoi pas plus rapide ?	Une seule carte de 12 Go, un modèle chargé à la fois, un contexte limité. C'est un choix de confidentialité.
Que se passe-t-il quand on ajoute un document ?	Le système compare les faits au dernier état appliqué, propose un plan avec des cases, n'applique que cela. Les lignes inchangées restent identiques à l'octet près ; une décision sur une ligne modifiée revient « à confirmer ».

Sur les limites et la sécurité

Question	Réponse
Le système est-il sécurisé ?	**Non, pas encore.** Pas d'authentification, SSH root par mot de passe, Ollama exposé au réseau local, conteneur en root. Reporté volontairement ; aucune donnée réelle n'est traitée. Ce serait la première chose à faire avant toute mise en service.
Peut-on lui faire confiance pour décider ?	Non, et ce n'est pas le but : il **prépare, vérifie et trace** ; l'humain décide (`valide_par`).
Qu'est-ce qui reste à faire ?	Fusion des doublons d'actifs, retrait par le code des citations inexistantes, calibrage des niveaux, durcissement du site, répéter le test d'injection en direct sur d'autres cas.
Avez-vous comparé avec une analyse humaine ?	Oui sur SanteTech, avec une réserve : l'analyse de référence (30 risques classiques) a été établie avec l'assistant IA et **reste à relire et valider par l'analyste**. Les agents en couvrent 16 sur 30, 7 partiellement, 7 pas du tout (sinistres, continuité, organisation) et classent plus haut. Sur ShoPix, un brouillon rédigé avec l'assistant (12 menaces, 9 retrouvées) n'est pas retenu comme analyse manuelle. Sur Nordval, la comparaison avec le corrigé est faite par l'analyste.

9. Les chiffres à connaître par cœur

Chiffre	Sens
97 % (435 sur 447)	Faits extraits dont le texte est réellement dans le document
96 %	Le bon passage est parmi les 8 premiers retrouvés
151 risques, **38** actifs	Cas Nordval (22 documents)
135 risques, **39** actifs	Cas SanteTech
13 min	Ajouter un document à une analyse existante
2 min au lieu de 30	Registre et synthèse établis par le code
48 à 56 %	Part de risques « Critique » (trop élevée)
16 / 7 / 7	Sur 30 risques de référence (SanteTech) : couverts / partiels / non couverts par les agents
640 → 22 500	Lignes de Python entre la V1 et la V2